

Controles de Seguridad

Orientados a la Infraestructura
Empresarial

BY NOVA TECH SOLUTIONS

1. INTRODUCCIÓN A LOS CONTROLES DE SEGURIDAD

Presentamos los controles que mantendrán el flujo seguro de los datos entre los departamentos de NovaTech y la infraestructura tecnológica, garantizando una respuesta activa y una mejora en el desempeño de la empresa frente a la situación en la que se encuentra.

Tomando en cuenta el cumplimiento de los leyes y normativas por las que se rige la empresa, para evitar grandes penalizaciones que no permitan la continuidad del negocio o caer en un punto de no retorno para nuestras operaciones.

Cada sección cumple el deber de prevenir futuros incidentes de seguridad, concientizar al personal, reforzar las aplicaciones y el software que se desarrolla internamente, monitorear los servicios que proporcionamos, y recuperar la continuidad de nuestras operaciones en caso de un incidente.

2. CONTROLES PREVENTIVOS

Se definen con el objetivo de impedir que alguna amenaza surja de una vulnerabilidad, evitando que ocurra un incidente de seguridad.

Gestión de Identidades y Accesos

Controlar el acceso de los repositorios Git y sistemas CRM para prevenir exfiltraciones. Con la responsabilidad de los propietarios de activos autorizar los premisos necesarios.

Desarrollo de Software Seguro

Integrar criterios de seguridad en el desarrollo de software para proteger código fuente de modificaciones no autorizadas.

Gestión Confidencial de Credenciales

Se prohíbe el uso de contraseñas en archivos de texto o en códigos fuente. Se debe usar un almacén digital para claves de cifrado y credenciales de bases de datos.

Capacitación y Concientización

Capacitación obligatoria sobre el manejo de los datos conforme a LFPDPPP, adaptada a lo que cada puesto puede hacer.

Hardening de Infraestructura en la Nube

Implementar configuraciones de seguridad estándar para todos los servicios de nube. Desactivando servicios innecesarios, cerrar puertos de administración a internet publico y forzar el uso de llaves SSH en lugar de su contraseña local.

Dualidad de Firma para Cambios Críticos

Se requiere que en cualquier cambio en configuraciones de producción o código maestro sea aprobado por al menos dos personas autorizadas.

Gestionar vulnerabilidades en la cadena de suministro

Mantener y hacer inventario de las librerías de terceros que usan sus plataformas.

3. CONTROLES DETECTIVOS

Sirven para identificar anomalías en crecimiento en la infraestructura empresarial.

Monitoreo de Infraestructura en la Nube

Supervisar continuamente servidores y bases de datos para detectar fallas de configuración o intrusiones.

Escaneos de "Shadow IT" (Tecnología en la Sombra):

Ejecutar escaneos periódicos para detectar dispositivos o aplicaciones de nube que los empleados estén usando para el trabajo sin autorización de TI.

Monitoreo de Anomalías en el Tráfico de Datos (Egresos):

Configurar alertas que se activen cuando se detecten transferencias de datos inusualmente grandes desde los servidores de NovaTech hacia el exterior.

Auditorías y Métricas de Desempeño

Revisión periódica mediante el ciclo PDCA y KPIs para validar la efectividad de controles frente a la metodología OCTAVE Allegro.

Reporte de Anomalías

Obligatoria para el personal, reporta inmediatamente cualquier vulnerabilidad detectada durante actividades habituales.

Evaluación de Vulnerabilidad

Realizar proceso continuo de revisión de los sistemas para encontrar debilidades técnicas antes de que se explote la vulnerabilidad.

Análisis de comportamiento de Entidades

Diseñar e implementar algoritmos que aprendan del comportamiento normal de los usuarios, para identificar amenazas internas que afecten a datos de los clientes.

4. CONTROLES CORRECTIVOS

Cumplen el objetivo de restaurar operaciones y mitigar el impacto una vez que se detecta un incidente.

Aislamiento Automático de Endpoints

Configurar los sistemas de seguridad para detectar virus o comportamiento sospechoso en computadora, servidor e infraestructura de la Nube, para que un afectado sea aislado automáticamente de la red corporativa.

Respallos Inmutables

Mantener copias de seguridad de los datos de clientes y empleados que no puedan ser borradas ni modificadas, protegiendo la información ante ataques de ransomware.

Estrategia de Respallos Inmutables y Fuera de Línea

Mantener copias de la información financiera y el código fuente en una ubicación que no sea borrrable ni modificable, incluso con permisos de administrador.

Plan de Comunicación de Crisis Pre-aprobado

Plantillas de comunicación legal y técnica listas para ser usadas en caso de una filtración de datos, cumpliendo con los tiempos que marca la ley mexicana.

Seguro de Ciberriesgos

Contratar una póliza que cubra gastos de recuperación de datos, multas legales por incumplimiento de la LFPDPPP y servicios de relaciones públicas. Ir agregando presupuesto para poder cumplir esta meta.

Análisis Forense Post-Mortem Obligatorio:

Después de cualquier incidente (menor o mayor), se debe realizar un peritaje técnico para entender la causa raíz y actualizar las políticas.

Aislamiento de Sistemas Comprometidos

Capacidad técnica del **CSIRT** para desconectar servidores o endpoints infectados de la red corporativa de manera inmediata.